CASE STUDY

The cPanel and WHM Authentication Bypass of 2026 (CVE-2026-41940): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

Hosting companies and admins who run their own web servers carried this one. On 28 April 2026 the vendor of cPanel and WHM, the hosting control panel that watchTowr, citing the vendor, puts behind north of 70 million domains [10] (**Reported**), shipped an emergency fix for a flaw in the login flow that let anyone who could reach the panel skip authentication entirely [1] [2] (**Confirmed**).

The fix came out under exploitation pressure (**Inferred** from the reports below). Namecheap blocked the panel ports for its customers hours before the vendor bulletin [12] (**Reported**), and KnownHost said exploits had succeeded in the wild before any fix existed [13] (**Reported**). CISA added the flaw to the Known Exploited Vulnerabilities (KEV) catalog on 30 April with a three-day deadline [4] [5] (**Confirmed**). A public proof of concept appeared on 29 April [10] (**Demonstrated**), and from about 30 April the flaw was mass-exploited to drop a Linux encryptor called "Sorry"; news citing Shadowserver put compromised cPanel IP addresses at 44,000 or more [14] (**Reported**). KEV now marks ransomware use as Known [4] (**Confirmed**). In July and October, researchers found hijacked GitHub repositories whose workflows scanned for the flaw from GitHub's own runners [15] [16] (**Reported**).

Key facts at a glance

Field	Value
Products	cPanel and WHM (including DNSOnly), and WP Squared (WP2) [1] [4]
Flaw	Authentication bypass in the login flow; unauthenticated remote access to the control panel; CWE-306 [2] [3]
Scores	CVSS 4.0 9.3 and CVSS 3.1 9.8, both from VulnCheck as CNA [2] [3]
Affected	All versions after 11.40 (ranges start at 11.40.0.0) [1] [2]
Fixed	11.86.0.41, 11.94.0.28, 11.102.0.39, 11.110.0.97, 11.118.0.63, 11.124.0.35, 11.126.0.54, 11.130.0.19, 11.132.0.29, 11.134.0.20, 11.136.0.5; WP Squared 136.1.7; 110.0.103 for CentOS 6 and CloudLinux 6 hosts on 110.0.50 [1]
Disclosed	Vendor advisory 28 Apr 2026; CVE published 29 Apr 2026 (reserved 22 Apr) [1] [2]
Credit	Sybre Waaijer, for the responsible report [1]
KEV	Added 30 Apr 2026, due 3 May 2026; ransomware use Known (catalog 2026.11.10) [4]
Named actor	None in any source opened [11] [14] [15] [16]
Exposure	About 1.5 million internet-exposed cPanel instances by a naive Shodan query (exposed, not confirmed vulnerable) [11]

Key findings

- **Exploitation was reported before the advisory.** KnownHost reported successful exploits before the fix and execution attempts as early as 23 February [13], a date Rapid7 describes as speculation [11] (**Reported**). CISA's own record graded exploitation active on 29 April [2] (**Confirmed**).
- **The vendor's words undersold it.** The changelog line for the fix reads "Fix an issue with session loading and saving" [7], and the advisory text does not state exploitation in the wild [1] (**Confirmed**). The exploitation record comes from CISA and from hosting providers [4] [13] (**Confirmed** and **Reported**).
- **The fix arrived in waves.** Changelogs date it 28 April for six tiers and 29 April for 11.130; the advisory added 11.124 on 1 May and 11.94 and 11.102 on 5 May [1] [7] [8] (**Confirmed**).
- **Ransomware came within a day of the proof of concept.** "Sorry" deployments are reported from about 30 April, a day after the public analysis [10] [14] (**Reported**), and KEV lists ransomware use as Known [4] (**Confirmed**).
- **Hijacked CI was turned into a scanner for the flaw.** Compromised GitHub repositories ran workflows that scanned for and attempted CVE-2026-41940 [15], and JFrog tied a later cluster to a Shai-Hulud descendant while finding no proof that downstream cPanel systems were exploited [16] (**Reported**).

Top recommendations

1. Confirm every cPanel, WHM, DNSOnly and WP Squared host runs a fixed build, update servers with updates disabled or pinned by hand, and hard-restart cpsrvd after updating [1] (**Confirmed** as vendor guidance).

2. Where a host cannot be patched yet, block inbound 2083, 2087, 2095 and 2096 and disable service subdomains, or stop cpsrvd and cpdavd [1] (**Confirmed** as vendor guidance).
3. Treat any host that was reachable before it ran a fixed build as possibly compromised (**Inferred**, since KnownHost reports attempts from February [13]). Run the vendor's current detection script, and on any indicator purge sessions, reset root and all WHM passwords, review wtmp and WHM access logs, and look for cron jobs, SSH keys and backdoors [1] (**Confirmed** as vendor guidance).
4. Rebuild rather than clean a root-compromised server: move accounts to a clean server, or reinstall and restore [1] (**Confirmed** as vendor guidance).
5. Search CI logs and runners for references to CVE-2026-41940, as JFrog advises [16] [17] (**Reported**).

Scope and method

This brief covers CVE-2026-41940 from its CVE reservation on 22 April 2026 to the KEV catalog of 10 November 2026, including the later GitHub Actions scanning and three cPanel-ecosystem KEV entries as context. It describes tradecraft at advisory level; no exploit detail is reproduced, and the public proof-of-concept repository is not linked. Hosting-tier patching of PHP is covered in PHP2Shell, October 2026, and the Shai-Hulud worms in npm Supply Chain Attacks.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: the vendor advisory and changelogs, the CVE, NVD and KEV records, the CISA alert, the CNA advisory, the Intelligence Hub data and the library's own files
Demonstrated	A researcher reproduced the mechanism and published it (watchTowr)
Reported	Stated by news or a named research firm and not confirmed in a primary
Inferred	This study's own reasoning from cited facts, labelled where it appears

All sources were opened on 11 November 2026. The vendor advisory page refuses scripted clients, so the same article (id 40073787579671) was read through the vendor's help-center API, which returns its body and timestamps [1]. Namecheap's status post now redirects to an index, and the KnownHost forum comments and the Shadowserver post were not opened; claims that depend on them are attributed to the news reports that relay them.

Part 1: what happened

Date	Event	Sources	Grade
23 Feb 2026	Earliest execution attempts KnownHost says it saw; Rapid7 describes the date as speculation	[11] [13]	Reported
22 Apr 2026	CVE-2026-41940 reserved by VulnCheck	[2]	Confirmed
28 Apr 2026	Namecheap blocks ports 2083 and 2087 for cPanel and WHM until patches exist; the vendor bulletin follows a few hours later	[12]	Reported
28 Apr 2026	Vendor advisory first published (12:05 PM CST; 16:19:18Z); mitigation steps changed at 03:19 PM CST; patched versions added at 04:36 PM CST. Builds 110.0.97, 118.0.63, 126.0.54, 132.0.29, 134.0.20 and 136.0.5 ship "CPANEL-52908: Fix an issue with session loading and saving"; WP Squared 136.1.7 ships the same ticket as a login authentication fix; CVE datePublic	[1] [2] [7] [9]	Confirmed
29 Apr 2026	CVE record published (15:10:37Z) and NVD publishes it (16:16:25); VulnCheck advisory; CISA ADP grades exploitation active, automatable, total impact; advisory adds required actions and a detection script; 130 changelog dates 130.0.18 with the fix	[1] [2] [3] [6] [8]	Confirmed
29 Apr 2026	watchTowr publishes a root-cause analysis and proof of concept; Rapid7 publishes its response (updated 30 Apr)	[10] [11]	Demonstrated; Reported
30 Apr 2026	CISA adds the flaw to KEV based on evidence of active exploitation, due 3 May; advisory adds the CentOS 6 and CloudLinux 6 path and 11.110 restart notes; Rapid7 ships authenticated checks	[1] [4] [5] [11]	Confirmed; Rapid7 Reported
By 30 Apr 2026	News reports the vendor has narrowed "all currently supported versions" to versions after 11.40 and adds WP Squared	[13]	Reported
From about 30 Apr 2026	Mass exploitation deploys "Sorry" ransomware	[14]	Reported
1 May 2026	Detection script withdrawn for false positives and replaced; 11.124 patch added	[1]	Confirmed
2 May 2026	News cites Shadowserver for at least 44,000 compromised cPanel IP addresses	[14]	Reported
3 May 2026	KEV due date; advisory updates patch versions for 11.110, 11.118, 11.126, 11.134 and 11.136	[1] [4]	Confirmed
4 May 2026	Detection script refined; the CVE Program ADP container, last updated this day, lists the watchTowr analysis and the ransomware report as references	[1] [2]	Confirmed
5 May 2026	Advisory adds patches for 11.94 and 11.102	[1]	Confirmed
26 May 2026	KEV adds CVE-2026-48172, LiteSpeed cPanel Plugin	[4]	Confirmed
15 Jun 2026	KEV adds CVE-2026-54420, LiteSpeed cPanel Plugin	[4]	Confirmed

Date	Event	Sources	Grade
12 to 13 Jul 2026	Malicious dev versions of 10 Packagist packages from one developer sync, carrying 583 workflow files	[15]	Reported
22 Jul 2026	Socket reports GitHub Actions workflows scanning for and attempting CVE-2026-41940	[15]	Reported
16 Sep 2026	KEV adds CVE-2026-87886, Acronis Backup plugin for cPanel & WHM	[4]	Confirmed
26 Oct 2026	NVD last modifies the record (Analyzed); JFrog ties "Shellpanel" artifacts to a cluster of 42 hijacked repositories, one of whose workflows scanned cPanel-related ports	[3] [16]	Confirmed; Reported
27 Oct 2026	CSO relays JFrog's advice to hunt CI logs for the CVE	[17]	Reported
10 Nov 2026	KEV catalog 2026.11.10 still lists ransomware use as Known	[4]	Confirmed

Discrepancies in the record

- **The 11.130 build.** The advisory and the CVE name 11.130.0.19, but the 130 changelog shows the fix in 130.0.18, dated 29 April [1] [2] [8] (**Confirmed**).
- **The 11.124 build.** The advisory names 124.0.35, but the 124 changelog lists 124.0.34 (2025) and 124.0.37 (8 May 2026) and no 124.0.35 [1] [8] (**Confirmed**). Admins on that tier can check for 124.0.37 or later (**Inferred**).
- **The CVE date.** The CVE datePublic is 28 April [2], while Rapid7 says it was assigned on 29 April [11] (**Confirmed**; Rapid7 **Reported**). It was reserved on 22 April [2], so "assigned" most likely means published (**Inferred**).

Part 2: the technical record

CVE	Class and weakness	Score	KEV (catalog 2026.11.10)
CVE-2026-41940	Authentication bypass via the cPanel and WHM login flow; CWE-306	CVSS 4.0 9.3 (AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N); CVSS 3.1 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)	Added 30 Apr 2026, due 3 May 2026, ransomware Known [2] [3] [4]

The mechanism, at advisory level. The CNA describes an authentication bypass in the login flow that lets unauthenticated remote attackers gain unauthorized access to the control panel [2] (**Confirmed**). watchTowr traced it to pre-authentication session files: on one code path, line breaks in login input were written into the session file without being stripped, and an encoding step for the password was skipped when the session cookie lacked its secret part, so attribute lines an attacker chose were honoured as authentication state when the session loaded. The patch moves the sanitising filter into the session save routine and changes how the password is encoded [10] (**Demonstrated**). That fits the vendor's own wording, "session loading and saving" [7] (wording **Confirmed**; the fit **Inferred**).

Weakness ids. The CNA, NVD and KEV all record CWE-306 and no other CWE [2] [3] [4] (**Confirmed**). Rapid7 calls the mechanism a carriage-return line-feed (CRLF) injection [11] (**Reported**). That would suggest CWE-93, but no record lists it, so this study does not bind it (**Inferred**).

What exploitation gives. CISA's decision record calls the flaw automatable with total technical impact [2] (**Confirmed**). Rapid7 says exploitation gives control of the host, its databases and its websites [11] (**Reported**). watchTowr cites cPanel's own figure of "north of 70 million domains" [10] (**Reported**).

Detection. The vendor's script looks for authentication markers injected into pre-authentication session files [1] (**Confirmed**). Its first version produced false positives and was replaced on 1 May and refined on 4 May [1] (**Confirmed**); results from the 29 April version are worth rerunning (**Inferred**). watchTowr published a detection artifact generator [10] (**Demonstrated**).

Part 3: who and why

Who found it. The CVE record marks discovery as external [2], and the vendor credits Sybre Waaijer with the responsible report [1] (**Confirmed**).

Who exploited it. No source opened names an actor for any phase. KnownHost reported exploitation before the fix without naming anyone [13]; the "Sorry" operators are unnamed and give only a Tox contact [14] (**Reported**). The encryptor is a Go program that appends .sorry, uses ChaCha20 with an RSA-2048 key wrap and leaves a README.md note; it is unrelated to a 2018 HiddenTear strain that used the same extension [14] (**Reported**).

The GitHub Actions scanning. Socket found malicious workflows on compromised repositories that used GitHub-hosted runners to scan for and attempt the flaw against internet-facing cPanel and WHM and to harvest credentials and secrets; it names no actor and gives no count of compromised servers [15] (**Reported**). JFrog linked "Shellpanel" artifacts to the same hijacked owner cluster as 42 armed repositories across 11 owners, one of whose workflows scanned cPanel-related ports with this exploit enabled. JFrog calls the payload a Shai-Hulud descendant, does not attribute it to the original Miasma operators, and calls the npm-to-cPanel link operational rather than proven [16] (**Reported**).

Why. The sources state no motive beyond the ransom note [14] (**Reported**). An unauthenticated, automatable, root-level flaw on a multi-tenant panel suits both extortion and credential theft (**Inferred**). This study does not link the ransomware wave and the GitHub Actions scanning to each other or to any ATT&CK group (**Inferred**).

Part 4: impact and response

Victims. News citing Shadowserver puts compromised cPanel IP addresses at 44,000 or more, with hundreds of compromised sites already indexed by Google [14] (**Reported**). No source opened gives a sector breakdown, and because one server hosts many customers' sites, IP counts understate the number of affected sites and owners (**Inferred**).

Hosting providers. Namecheap blocked ports 2083 and 2087 to protect customers until patches were available [12], and KnownHost publicly reported exploitation on disclosure day [13] (**Reported**).

The vendor. The advisory went up at 12:05 PM CST on 28 April, and its change log records revisions on nine days through 11 May, covering mitigations, patched builds, required actions, the detection script and older tiers [1] (**Confirmed**). The vendor first described the scope as all currently supported versions and later narrowed it to versions after 11.40, adding WP Squared [13] (**Reported**). CentOS 7 and CloudLinux 7 hosts move to the 11.110 tier [1] (**Confirmed**).

CISA and KEV. CISA's ADP graded exploitation active on 29 April [2], added the flaw to KEV on 30 April "based on evidence of active exploitation" [5], and set a due date of 3 May under BOD 22-01, three days later [4] (**Confirmed**). The KEV name covers WebPros cPanel & WHM and WP2 (WordPress Squared) [4] (**Confirmed**). NVD records the same dates [3], and VulnCheck lists the flaw in its own KEV [6] (**Confirmed**). The Intelligence Hub indexes the KEV row dated 30 April and the watchTowr research row dated 29 April [18] (**Confirmed**).

The ecosystem after. KEV added three more cPanel-ecosystem flaws in 2026: two in the LiteSpeed cPanel Plugin (26 May and 15 June) and one in the Acronis Backup plugin for cPanel & WHM (16 September), each with ransomware use Unknown [4] (**Confirmed**).

Part 5: the defender and vulnerability-management view

A hosting control panel is an edge device with root behind it: it faces the internet on well-known ports and holds every tenant's sites and databases (**Inferred**).

Control	Where it meets the record
Inventory every cPanel, WHM, DNSOnly and WP Squared host, including servers with updates pinned or disabled	Pinned servers must be updated by hand [1]
Check the installed build against the tier table, not the version family	Eleven fixed builds; the 11.124 and 11.130 changelogs disagree with the advisory [1] [8]
Restrict the panel ports to admin networks	Vendor mitigation, Namecheap's interim block [1] [12]
Count the KEV clock from the advisory, not the CVE	Advisory 28 Apr, CVE 29 Apr, KEV 30 Apr, due 3 May [1] [2] [4]
Rerun detection after each script revision	Script replaced 1 May, refined 4 May [1]
Purge sessions and rotate root and WHM credentials on any indicator	Vendor remediation [1]
Back up tenant data off the server and test restores	"Sorry" encrypts files on Linux hosts [14]
Watch CI for scanning or exploitation traffic leaving your runners	GitHub Actions workflows used as scanners [15] [16]

What is overstated and what is understated

- **Overstated:** the 1.5 million figure is a naive Shodan count of exposed instances, not vulnerable hosts [11]. Socket's figure of about 6,100 matching workflow files counts file matches by campaign identifier, not victims [15]. The 23 February start is one host's statement, which Rapid7 describes as speculation [11] [13]. Early wording that every supported version was affected was later narrowed to versions after 11.40 [13] (**Reported**). JFrog itself does not claim downstream cPanel compromise from the GitHub cluster [16] (**Reported**).
- **Understated:** the vendor advisory never states exploitation, and its changelog line reads as a routine session fix [1] [7] (**Confirmed**), yet KEV marks ransomware use as Known [4] (**Confirmed**) and Shadowserver, via news, counts at least 44,000 compromised IPs [14] (**Reported**). Each compromised IP can be a server carrying many tenants (**Inferred**). Patches for the 11.94 and 11.102 tiers arrived a week after disclosure [1] (**Confirmed**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `technique_to_d3fend.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl` and `data/weaknesses/` files [19] (**Confirmed**). No source names ATT&CK technique ids; each row is this study's mapping (**Inferred**). None of the bound ids is revoked [19] (**Confirmed**). cPanel is a web hosting platform and no source describes an industrial effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

No ATT&CK group, campaign or software object covers the cPanel exploitation, the "Sorry" encryptor or the GitHub Actions scanning [19] (**Confirmed**), and no source names an actor (**Reported**).

Object	ATT&CK id	Relationship to this record
Shai-Hulud	S9008	Lineage only: JFrog calls the 2026 cluster's payload a Shai-Hulud descendant without naming a variant (26 Oct) [16]; not bound to cPanel exploitation
Mini Shai-Hulud	S9043	Named for completeness; JFrog does not say the payload is this variant [16] [19]; not bound

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1595.002	Vulnerability Scanning	Reconnaissance	GitHub Actions workflows scan for the flaw (Socket, 22 Jul); broad scan of cPanel-related ports (JFrog, 26 Oct)	[15] [16]
T1584.006	Web Services	Resource Development	Compromised GitHub repositories and GitHub-hosted runners used as scanners (Socket, 22 Jul; JFrog, 26 Oct)	[15] [16]
T1190	Exploit Public-Facing Application	Initial Access	Exploitation before the fix (KnownHost, reported 30 Apr); SSVC active (29 Apr); KEV (30 Apr); mass exploitation (from about 30 Apr)	[2] [4] [5] [13] [14]
T1195.002	Compromise Software Supply Chain	Initial Access	Malicious dev versions of 10 Packagist packages carry the workflows (12 to 13 Jul; Socket, 22 Jul)	[15]
T1552	Unsecured Credentials	Credential Access	Workflows harvest credentials and secrets (Socket, 22 Jul)	[15]
T1486	Data Encrypted for Impact	Impact	"Sorry" encryptor (BleepingComputer, 2 May); KEV ransomware use Known (catalog 2026.11.10)	[4] [14]

Fit notes (**Inferred**): the forged session is part of the T1190 exploitation, so Valid Accounts (T1078) is not bound; the attacker never holds a real credential. T1584.006 fits the hijacked repositories as borrowed infrastructure, and T1195.002 binds only the Packagist delivery of the workflows, not any cPanel host. T1552 is an inexact fit, because Socket does not say where the credentials were stored. The cron jobs, SSH keys and backdoors in the vendor's remediation are things to check for, not observed behavior, so Cron (T1053.003) and SSH Authorized Keys (T1098.004) are not bound.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-306	Missing Authentication for Critical Functionality (KEV and CNA wording: Missing Authentication for Critical Function)	CVE-2026-41940 (CNA, NVD, KEV)	[2] [3] [4] [19]

No record lists a CAPEC entry for this CVE [2] [3] (**Confirmed**). The library relates CWE-306 to CAPEC-12, CAPEC-36, CAPEC-62, CAPEC-166 and CAPEC-216 [19] (**Confirmed**), and none of them describes a forged login session, so none is bound (**Inferred**). The nearest pattern by mechanism, CAPEC-196 Session Credential Falsification through Forging, is related in the library to CWE-384 and CWE-664, not CWE-306, and is not bound either [19] (**Confirmed**; the fit is **Inferred**). CWE-93 is left out as explained in Part 2. See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Traffic Filtering, Network Traffic Filtering	T1190	Blocking inbound 2083, 2087, 2095 and 2096 [1] [12]
Authentication Cache Invalidation, Credential Rotation, Credential Revocation	T1552	Purging sessions and forcing root and WHM password resets [1]; rotating secrets exposed to the workflows [15]
Restore File, File Integrity Monitoring	T1486	Reinstalling and restoring root-compromised servers [1]; "Sorry" encryption [14]

The control that decides this case, updating to a fixed build, corresponds to Software Update, which the library relates to T1195.002 but not to T1190 [19] (**Confirmed**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/cpanel-whm-cve-2026-41940.json` (open in Navigator). Scores: 75 for behavior in the CVE, KEV or CISA record, 50 for a vendor research or news report, 25 for an inexact fit. Each technique's comment names its source numbers.

Cross-cutting themes

- **Management planes are the new file-transfer servers.** A zero-day, then mass exploitation of an internet-facing management surface, is the shape of Cl0p File Transfer 2023 and SharePoint ToolShell 2025; here it reached multi-tenant hosting (**Inferred**).
- **Changelog wording is not a severity signal.** A "session loading and saving" fix was an unauthenticated root bypass [7] [10]; triage should key on KEV and CISA's decision record, not vendor prose [2] [4] (**Inferred**).
- **Hosting providers are first responders.** Namecheap and KnownHost acted and spoke before the vendor's bulletin and KEV [12] [13] (**Reported**); the hosting tier's patch reach is also the theme of PHP2Shell, October 2026 (**Inferred**).
- **Supply-chain worms now carry exploits for other people's servers.** The workflows in [15] [16] turned hijacked CI into a scanner, a step beyond the credential theft traced in npm Supply Chain Attacks (**Inferred**).

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	WebPros cPanel, Security: CVE-2026-41940, cPanel & WHM / WP2 Security Update 04/28/2026, first published 28 Apr 2026 (read through the vendor's help-center API, article 40073787579671)	support.cpanel.net/hc/en-us/articles/40073787579671-...	2026-11-11	Confirmed
2	CVE Program record CVE-2026-41940 (CNA VulnCheck, with the CISA ADP and CVE Program containers), CVE Services API	cveawg.mitre.org/api/cve/CVE-2026-41940	2026-11-11	Confirmed
3	NVD, CVE-2026-41940 (page and API)	nvd.nist.gov/vuln/detail/CVE-2026-41940	2026-11-11	Confirmed
4	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
5	CISA, CISA Adds One Known Exploited Vulnerability to Catalog, 30 Apr 2026	cisa.gov/news-events/alerts/2026/04/30/...	2026-11-11	Confirmed
6	VulnCheck, cPanel and WHM Authentication Bypass via Login Flow, 29 Apr 2026	vulncheck.com/advisories/cpanel-and-whm-authentication-bypass-via-login-flow	2026-11-11	Confirmed
7	cPanel, 136 change log (and the 110, 118, 126, 132 and 134 change logs)	docs.cpanel.net/changelogs/136-change-log/	2026-11-11	Confirmed
8	cPanel, 130 change log (and the 124 change log)	docs.cpanel.net/changelogs/130-change-log/	2026-11-11	Confirmed
9	WP Squared, changelog, version 136.1.7, 28 Apr 2026	docs.wpsquared.com/changelogs/versions/changelog/#13617	2026-11-11	Confirmed
10	watchTowr Labs, cPanel and WHM authentication bypass CVE-2026-41940, 29 Apr 2026	labs.watchtowr.com/the-internet-is-falling-down-...	2026-11-11	Demonstrated
11	Rapid7, ETR: CVE-2026-41940 cPanel and WHM authentication bypass, 29 Apr 2026, updated 30 Apr 2026	rapid7.com/blog/post/etr-cve-2026-41940-...	2026-11-11	Reported
12	BleepingComputer, cPanel and WHM emergency update fixes critical auth bypass bug, 29 Apr 2026	bleepingcomputer.com/news/security/cpanel-whm-emergency-update-...	2026-11-11	Reported
13	BleepingComputer, critical cPanel and WHM bug exploited as a zero-day, PoC now available, 30 Apr 2026	bleepingcomputer.com/news/security/critical-cpanel-and-whm-bug-...	2026-11-11	Reported
14	BleepingComputer, critical cPanel flaw mass-exploited in "Sorry" ransomware attacks, 2 May 2026 (citing Shadowserver)	bleepingcomputer.com/news/security/critrical-cpanel-flaw-...	2026-11-11	Reported
15	Socket, GitHub Actions abuse powers cPanel and WHM exploitation, 22 Jul 2026	socket.dev/blog/github-actions-abuse-powers-cpanel-and-whm-exploitation	2026-11-11	Reported
16	JFrog Security Research, Beyond testmetest: 42 hijacked GitHub repos, 26 Oct 2026	research.jfrog.com/post/beyond-testmetest-42-hijacked-github-repos/	2026-11-11	Reported
17	CSO, attackers compromised 42 GitHub repositories, 27 Oct 2026	csoonline.com/article/4241496/...	2026-11-11	Reported

#	Source	URL	Opened	Grade
18	Team Star Wolf Intelligence Hub, feed.json (KEV row and research row)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed
19	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), and `data/weaknesses/cwe.jsonl` and `capec.jsonl`	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Confirmed

Not opened, so not cited as sources: Namecheap's status post (redirects to its status index), the KnownHost comments on the r/cpanel forum (blocked), the Shadowserver post on X (requires a browser session), and the cPanel 86, 94 and 102 change logs (not found).

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- PHP2Shell, October 2026, npm Supply Chain Attacks, The Ransomware Ecosystem, Cl0p File Transfer 2023, SharePoint ToolShell 2025, The Year 2026 in Intrusions, Timeline
- Other 2026 edge and management-plane studies: The BeyondTrust Remote Support and PRA command injection, The PAN-OS GlobalProtect authentication bypass, The Cisco Catalyst SD-WAN authentication bypass, The Citrix NetScaler zero-days, The Ivanti Connect Secure zero-day chain
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Web Application Security Reference, Supply Chain Security Reference, Ransomware Defense Reference, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Software: S9008 Shai-Hulud, S9043 Mini Shai-Hulud
- Techniques: T1190 Exploit Public-Facing Application, T1595.002 Vulnerability Scanning, T1584.006 Web Services, T1195.002 Compromise Software Supply Chain, T1552 Unsecured Credentials, T1486 Data Encrypted for Impact
- CAPEC: CAPEC-196 (nearest pattern, not bound)
- Navigator layers, including this study's layer, cpanel-whm-cve-2026-41940.json
- The Team Star Wolf Intelligence Hub

- All case studies